Critical Infrastructure Security

IY5612 (IY3612/IY4612) — Academic Year 2024/2025 (Unit 7)

Stephen D. Wolthusen
stephen.wolthusen@rhul.ac.uk

Department of Information Security and Communication Technology
Norwegian University of Science and Technology, Norway

and

Department of Information Security
Royal Holloway, University of London, United Kingdom

Unit 7— Security of Control System Components

Contents

SCADA and DCS Systems

State Estimation

Security of Control Systems Components

Security of Control System Components
- Introduction
- Attacks on SCADA Systems
- Intrusion Detection in Control Systems

Part III

Security of Control System Components

Component Security
Security of Control System Components

So far we were mainly concentrated on abstract threats to cyber-physical and control systems, showing that these are increasingly relying on routed (TCP/IP) networks and interconnected

Here we describe some security concerns in control system components:

- Threats to availability
- Threats to integrity
- Changes to safety systems

Recommended Reading

- M. E. Luallen:
  Critical Control System Vulnerabilities Demonstrated — And What to Do About Them
  SANS Whitepaper, Nov. 2011
- N. O. Tippenhauer, C. Pöpper, K. Bonne Rasmussen, S. Capkun:
  On the Requirements for Successful GPS Spoofing Attacks
  In: Proceedings of the 18th ACM Conference on Computer and Communications Security (ACM CCS 2011), Chicago, IL, USA, Oct. 2011, pp. 75–86

SCADA System Requirements

Confidentiality may be a concern in control systems, but most control networks are predictable with limited entropy

- Emphasis must be on availability and integrity instead

SCADA systems encompass a broad range of operating systems and layered components that is far more eclectic than any found in a regular network

- Partly this is because of specific operating system requirements, partly because of products from multiple vendors and multiple generations ending up in mixed use
- Unlike server and desktop systems, life expectancy can easily exceed 10 years

Remote Code Injection

At the lowest level, changing and replacing code in a sensor and actuator is straightforward:

- Simple microcontrollers are replaced by components that can have almost the same functionality as a general-purpose computer
- A sensor (e.g. for temperature!) running some embedded operating system connected to an IP-based field bus is not unusual — but hence all standard techniques for vulnerability analysis and penetration testing apply

The same is also true for PLC systems, even if these may run on non-standard operating systems

- Code injection can be performed accidentally by operators: Firmware and other software updates are typically not authenticated

Component Robustness and Beyond

Above the level of individual SCADA components, other obvious targets are the Data Historian and the configuration databases used by the HMI and MTU systems

- These are still typically implemented without much in the way of access control (i.e. pre-shared and rarely-changed key material)
- Integrity protection and control over provenance of code and data is also generally not enforced e.g. using cryptographic mechanisms

Attacks such as those seen in the Stuxnet payload fall (partly) in this category

- Main problem: How to ensure that code loaded onto PLC or component is what is stored in the configuration database?

Denial of Service (1)

Denial of Service attacks can come in a number of forms:

- Overloading (e.g. distributed Denial of Service) are difficult to defend against unless a bound for “normal” load can be established
- Firewalls can help, but are rarely deployed consistently in control systems and are not effective if required bandwidth is exhausted
  - Field bus systems or wireless links are relatively easy to saturate to a point where latency and jitter become unacceptable
- Overloading is also easier to accomplish against component CPUs — “spare” capacity is much lower than for standard computer systems: For an availability threat merely slowing down operation can be sufficient

Denial of Service (2)

Denial of service through protocol disruption:

- If an attacker is able to inject messages, even encrypted channels are easy to disrupt e.g. by simply sending TCP RST segments
- While this will not affect integrity or confidentialty of an encrypted channel, it **will** force re-establishment of the session, potentially requiring lengthy re-synchronisation
- Similar disruptions can also occur at higher protocol levels, e.g. for DNP3, IEC 61850, or OPC despite security mechanisms

Note that where firewalls or other active security components are deployed, these make good targets for effecting denial of service

- Adding a firewall rule or two may be all that is required

Denial of Service (3)

Loss of configuration or forced restart:

- Deleting code or configuration data on a component will require shut-down and re-installation of all or part of the affected system unless component is redundant and non-critical
- Repeatedly “hitting” a vulnerable component (e.g. weak TCP/IP stack or application) forcing a re-start or corrupting configuration leading to continuous re-boot
- This also applies to inconsistencies in other elements of the applications and protocol stack involved including time reference signals

Other security mechanisms — particularly identification and authentication as well as access control relying on key management and authentication protocols

Denial of Service Example

GPS Time (1)

Many, mostly distributed, control systems but also applications such as telecommunications networks rely on timing, either relative or (more typically) real time to synchronise

- Standard time protocols such as NTP used in computers are insufficient for these purposes
- This is also e.g. the case for state estimators that must keep a very precise time-base
- A common source for time signals is therefore the **Global Positioning System** GPS, which is accurate to within 14ns (more practically 100ns)
- Where even this is not sufficiently accurate, augmentation mechanisms such as Differential GPS can be used to reduce errors and enhance confidence interval

Denial of Service Example

GPS Time (2)

GPS signals are very weak, so jamming has long been known to be a problem

- Jammers are easy and cheap to build, and because of the relative power required also difficult to detect

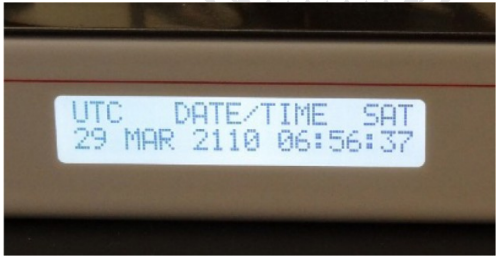
In addition, the problem of spoofing the civilian GPS signal has been known for a decade

- Civilian GPS signals are not authenticated or integrity-protected, so can be replaced easily with time-shifted copies (destroying TOA ranging) or arbitrary messages
- As with many embedded protocols, input validation may also lead to error conditions when “fuzzing” protocols

Denial of Service Example
GPS Time (3)

Consequences of time signal loss:

- Sensor readings and commands may be ignored in the most benign case
- If measurements are manipulated but still plausible, more interesting attacks become possible, giving wrong readings or causing activity at the wrong time
- Components can also go into error states that are difficult to recover from . . .



Source: Arbiter Systems

Denial of Service Example

GPS Time in PMUs

One application in which very precise time is required is in **Phasor Measurement Units** (PMUs)

- These are highly accurate devices recently (late 1980s) developed and beginning to be deployed across electical power networks to measure phase angles
- Distributing PMUs across a wide-area network system gives a very precise view of the network and input to grid control
- For PMUs to be useful they must have time resolution better than $1\mu s$ (within a few hundred *ns*) and must deliver reports at a frequency of 10 . . . 50 Hz
- These devices are increasingly being deployed in smart grids – for example, both China and the North American Synchrophasor Initiative roll out MPUs productivley
- Devices are crucial for many tasks in the smart grid, but rely on GPS time signals. . .

Denial of Service Example

GPS Location

GPS is of course mainly used as a Global Positioning System

- While GPS sat nav is used occasionally to drive into water obstacles, alternatives to precision navigation are less easy to obtain elsewhere
- Aviation and marine systems rely on highly accurate navigation but have limited recourse to other positioning aids
- Consider e.g. a deep-water drilling rig required to position a pipe of several km length within a few metres

Given the ubiquity of GPS-derived time and location signals, it is rather surprising that these signals are not only relatively trivial to spoof, but that detection and recovery is quite difficult

Remote Management

Even where in principle an air gap is assumed, vendors of control system equipment may wish to have remote access

- Continuous monitoring for correct operation and faults, preventive maintenance and even technical assistance is offered by equipment vendors
- This typically gives yet another reason to breach air gaps, so conventional network security means such as firewalls and IDS need to be deployed
- Similarly, remote access to HMI is often enabled in the name of efficiency and expediency

Accessible SCADA Systems

Lack of air gaps, mis-configured or non-existent firewalls results in control systems and their components being exposed to the public Internet or at least via *war-driving*

- Network scans, banner grabbing, and fingerprinting will hence result in large amounts of useful information
- Control system vendors may have dedicated MAC address blocks, allowing identification of interesting MAC addresses
- Banners can identify operating systems, components, and descriptive information
- Web-based interfaces or OPC can even give explicit service availability information
- Search engines such as Shodan make use of this, and e.g. Metasploit has ready vulnerabilities online

Intrusion Detection

Intrusion Detection in Control Systems (1)

Intrusion detection techniques can be divided into three broad categories:

Signature-Based Audit (sensor) data is processed and matched against signatures of known adversarial behaviour

Anomaly-Based The monitored system provides a baseline of normal behaviour, which is then used to identify deviations for both events and patterns

Specification-Based An explicit model (specification) of the monitored system's behaviour is used and deviations in events and event patterns are sought

Intrusion Detection

Intrusion Detection in Control Systems (2)

Signature-based IDS can be used in control systems — e.g. the Snort system has some SCADA-specific rules and preprocessors (e.g. for Modbus and DNP3)

- The Quickdraw rule sets also adopted by other IDS/IPS vendors can at least filter out some harmful commands (e.g. scanning, read and write requests)
- As with any signature-based mechanism, the utility of vulnerability signatures varies – but it may not always be possible to patch known vulnerabilities

Specification-based systems would benefit from the more regular character of control systems, but to be successful **all** possible legitimate states must be characterised

- An emergency state or mode change must not cause countermeasures to be triggered

Intrusion Detection

Intrusion Detection in Control Systems (3)

Anomaly detection must rely on classifying a data set (events, network traffic) into several classes, typically only normal or anomalous

- A large number of techniques exist, most of which rely on the availability of training data sets
- Data sets may contain noise similar to actual anomalies, and not necessarily following standard probability distributions (e.g. Gaussian or white noise)
- Particularly in control systems, normal data set changes over time: Processes creating data are rarely stationary
- Deciding whether a datum should be classified as normal or anomalous may therefore require knowledge (or estimate) of system state

A “Serious” ICS Failure

But does it **matter**?

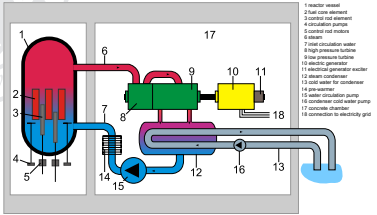
- Stuxnet (and its cousins, Duqu, Flame, and Gauss) may have been an extreme anomaly given its level of sophistication (as part of the Olympic Games programme)
- SCADA systems may be vulnerable, but are these actually targeted? Publicly documented cases show very limited actual harm, allow “SCADA security consultants” to
- However, *reconnaissance* is ongoing at a significant level of activity both with operators and control systems equipment and software manufacturers
- 40% of reported incidents by the US ICS-CERT affect the energy sector (electricity, oil and gas)

A “Serious” ICS Failure

On 9 Nov. 2012, the PPL Susquehanna Unit 2 nuclear power station had to be scrammed (shut down) manually

- The ICS controlling feedwater flow (including water level) had failed and was inoperative
- The control system affected was not the fail-safe (control rods), but in a boiling water reactor, feedwater is used as a secondary control
- No safety hazards (both emergency cooling systems were triggered), but a loss of 1250MW generation
- Reason for ICS failure is as yet unidentified

Source: Nuclear Power International



Safety Instrumentation Systems

As identified before, **Safety Instrumentation Systems** (SIS) were once considered to be the last line of defence against malfunctions and attacks against SCADA systems

- Attacks such as the DarkEnergy/Industroyer attacks (2016) and related Triton/Trisys attacks (2017) have demonstrated that SIS are vulnerable, and that attackers have learned to target these explicitly
  - The Triton perpetrators — believed to be of Russian origin — were again attacking OT/SIS systems e.g. in 2019 and seem to have scoped the target system for over a year
  - Tools and techniques evolve, Sandworm's PIPEDREAM toolkit discovered in 2022 clearly points to this becoming an almost conventional target

Summary

This section provided material on

- Attacks on SCADA systems
- Threats to Integrity
- Threats to Availability
- Threats to Safety Instrumentation Systems